UNIDAD 5 · CLASE 1 Resumen

El administrador de la base:
usuarios, roles, permisos y auditoría

1. El rol del administrador de bases de datos (DBA)

- **Mandato del DBA:** Pasa de ser únicamente «quien escribe consultas» a «quien responde por los datos». Sus responsabilidades centrales son garantizar la **disponibilidad**, **integridad** y **seguridad** de los datos, sumadas al rendimiento.

- **Mapa de tareas en la materia:**
  - *Estructura e integridad:* Unidades 1 y 4.
  - *Consistencia transaccional:* Unidad 1.
  - *Optimización y rendimiento:* Unidades 2 y 3.
  - *Identidades, permisos y auditoría:* Unidad 5 (Clase 1).
  - *Amenazas y protección de datos personales:* Unidad 5 (Clase 2).
  - *Mantenimiento operativo (respaldo y monitoreo):* Unidad 6.

- **Contexto Food Store:** Hasta la Unidad 4 se trabajó con una única cuenta dueña del esquema con privilegios totales. En producción, la aplicación web jamás debe conectarse con dicho usuario, ya que ante una fuga de credenciales un atacante podría alterar o destruir la base de datos completa.

2. Usuarios y roles en PostgreSQL

- **Concepto unificado (ROLE):** Desde PostgreSQL 8.1 no existen entidades separadas para "usuarios" y "grupos"; todo es un objeto ROLE. La sentencia CREATE USER es azúcar sintáctico de CREATE ROLE ... LOGIN.

- **Atributos y sintaxis:**
  - LOGIN / NOLOGIN: Define si el rol puede autenticarse y abrir sesiones.
  - PASSWORD: Almacena la credencial cifrada por el motor.
  - SUPERUSER / NOSUPERUSER: Omite todas las comprobaciones de permisos. **Nunca debe asignarse a un rol de aplicación**.
  - CREATEDB, CREATEROLE: Permisos administrativos para instanciar bases o gestionar identidades.
  - VALID UNTIL, CONNECTION LIMIT: Restricciones operativas sobre fecha de vencimiento y concurrencia máxima.

- **Roles de grupo vs. roles de login:** La buena práctica consiste en definir permisos sobre roles de grupo (NOLOGIN) según la función (lectura, escritura, soporte, etc.) y asociar las credenciales de conexión reales (LOGIN) mediante membresía (GRANT grupo TO login).
- **Diferencia entre rol del motor y columna de negocio:** La columna usuario.rol (ENUM: ADMIN, USUARIO) sólo rige la lógica interna de la aplicación (qué pantallas mostrar), pero

no impone restricciones de seguridad en el motor SQL. La autorización estricta a nivel de base se gestiona mediante GRANT/REVOKE o Row-Level Security.

3. Permisos: el modelo GRANT

- **Privilegios sobre objetos:**
  - SELECT: Lectura sobre tablas, vistas o columnas específicas.
  - INSERT, UPDATE: Escritura y modificación de registros.
  - DELETE: Eliminación de filas individuales.
  - TRUNCATE: Vaciado completo de tablas (no dispara triggers por fila).
  - REFERENCES: Permite crear claves foráneas vinculadas.
  - EXECUTE: Permite ejecutar funciones y procedimientos almacenados.
  - USAGE: Habilita el acceso y uso sobre esquemas, tipos y secuencias.
  - CREATE: Creación de nuevos objetos dentro de un esquema o base.
- **Punto de partida cero:** Los roles recién creados carecen de privilegios sobre esquemas u objetos ajenos; el acceso debe otorgarse de forma explícita comenzando siempre por GRANT USAGE ON SCHEMA.
- **Permisos por columna:** Permite limitar sentencias (por ejemplo GRANT SELECT (id, nombre, mail) ON usuario...) para no exponer datos sensibles.
- **Herencia y cambio de contexto:** La membresía hereda privilegios automáticamente (INHERIT). Para limitar temporalmente una sesión administrativa a un rol de menor alcance se utiliza SET ROLE <rol> y RESET ROLE.
- **Permisos por defecto (ALTER DEFAULT PRIVILEGES):** Automatiza la asignación de permisos sobre objetos que se creen a futuro dentro de un esquema.
- **Row-Level Security (RLS):** Control de acceso a nivel de fila mediante políticas (CREATE POLICY ... USING (...)) que el motor aplica automáticamente, evitando depender de que la aplicación recuerde filtrar con WHERE usuario_id = ...

4. El principio de mínimo privilegio y diseño en Food Store

Cada entidad debe tener únicamente los permisos mínimos indispensables para su operativa.

Esquema de roles diseñado para Food Store

Rol	Tipo	Objetos y privilegios otorgados	Propósito
rol_app_lectura	Grupo	SELECT en v_productos_vigentes,	Servir el catálogo público

	(NOLOGIN)	v_categorias_vigentes	
rol_app_escritura	Grupo (NOLOGIN)	SELECT, INSERT, UPDATE en pedido, detalle_pedido; EXECUTE en sp_crear_pedido *(sin DELETE ni TRUNCATE)*	Flujo de compras
rol_soporte	Grupo (NOLOGIN)	SELECT en v_usuarios_publico, v_pedidos_resumen	Atención al cliente sin exponer claves
rol_reportes	Grupo (NOLOGIN)	SELECT en mv_ventas_categoria_mes y vistas analíticas	Panel gerencial de lectura
app_web	Login (LOGIN)	Miembro de rol_app_lectura y rol_app_escritura	Conexión del backend de la aplicación
admin_datos	Login (LOGIN)	Dueño del esquema, con atributos CREATEDB y CREATEROLE *(sin SUPERUSER)*	Administración / DBA

5. Auditoría de accesos y operaciones

- **Loguear vs. Auditar:**
  - *Loguear:* Registrar eventos técnicos para diagnóstico y rendimiento.
  - *Auditar:* Generar un registro formal e inalterable para rendición de cuentas (*quién*, *qué*, *cuándo* y *desde dónde*).
- **Mecanismos nativos en PostgreSQL:**
  - log_statement: Configurable en none, ddl, mod (DDL + modificaciones) o all.
  - log_connections / log_disconnections: Registro de aperturas y cierres de sesión.
  - pg_stat_activity: Vista para inspeccionar conexiones activas y consultas en ejecución en tiempo real.
  - pg_stat_statements: Extensión para analizar métricas agregadas de rendimiento y detectar patrones anómalos.

- **Extensión pgaudit:** Permite granularidad por rol y clase de sentencia, descendiendo a auditar operaciones anidadas dentro de funciones y procedimientos.
- **Criterios para la política de auditoría:**
  - *Debe auditarse:* Intentos fallidos de login, cambios de DDL, sentencias GRANT/REVOKE, modificaciones al campo de negocio usuario.rol y sentencias DELETE/TRUNCATE directas (ya que el sistema opera con baja lógica).
  - *No debe auditarse:* Contraseñas en texto plano, consultas de lectura rutinarias sobre datos no críticos ni volcados masivos de datos personales (el archivo de auditoría es en sí un activo sensible).

6. Asistencia con Inteligencia Artificial

- **Rol de la IA:** Se utiliza para generar propuestas de esquemas y para auditar catálogos del motor (information_schema.role_table_grants, pg_roles) extrayendo matrices de permisos de forma automatizada.
- **Validación humana obligatoria:** La IA tiende a sugerir comandos laxos para simplificar el mantenimiento (por ejemplo, proponer GRANT ALL ON ALL TABLES...). Dichas propuestas deben ser rechazadas y documentadas en la bitácora técnica, validando manualmente que ningún rol de aplicación adquiera privilegios destructivos o administrativos.

UNIDAD 5 · CLASE 1 Resumen

**El administrador de la base:
usuarios, roles, permisos y auditoría**

7. Script consolidado (roles.sql)

```
-- 1. Roles de grupo
CREATE ROLE rol_app_lectura;
CREATE ROLE rol_app_escritura;
CREATE ROLE rol_soporte;
CREATE ROLE rol_reportes;

-- 2. Uso del esquema
GRANT USAGE ON SCHEMA public
TO rol_app_lectura, rol_app_escritura, rol_soporte, rol_reportes;

-- 3. Asignación de privilegios específicos
GRANT SELECT ON v_productos_vigentes, v_categorias_vigentes
TO rol_app_lectura;

GRANT SELECT, INSERT, UPDATE ON pedido, detalle_pedido
TO rol_app_escritura;

GRANT EXECUTE ON PROCEDURE sp_crear_pedido(BIGINT, forma_pago, JSONB)
TO rol_app_escritura;

GRANT SELECT ON v_usuarios_publico, v_pedidos_resumen
TO rol_soporte;

GRANT SELECT ON mv_ventas_categoria_mes
TO rol_reportes;

-- 4. Roles de login y membresías
CREATE ROLE app_web WITH LOGIN PASSWORD 'cambiar_en_produccion';
GRANT rol_app_lectura, rol_app_escritura TO app_web;
```